CHAPTER 4

Threat Intelligence Without an Analyst

How a small organization can use free, current data about real attacks to decide what to fix first

In this chapter

- What threat intelligence is, in plain language
- The free catalog of vulnerabilities that attackers are using right now
- A five-step monthly loop: collect, match, re-score, decide, verify
- A worked example with a fictional 22-person dental practice
- How to read the results without fooling yourself
- A one-page owner summary, a monthly log, a checklist, and a free exercise

On February 12, 2024, someone logged in to a remote-access portal at Change Healthcare with a stolen username and password. The portal did not ask for a second factor, such as a code from a phone. Nine days later, ransomware was running inside the network, and for weeks pharmacies, hospitals, and small medical offices across the United States struggled to process claims and get paid (Witty, 2024).

Most of the small practices affected had never heard of Change Healthcare's portal. They did nothing wrong. But the same two weaknesses, an internet-facing login and an account without multi-factor authentication (MFA), exist in thousands of small offices, and attackers use them every day.

Large companies employ threat intelligence analysts whose job is to follow attackers and tell the organization which weaknesses matter this week. A dentist, a grocery store manager, or a college registrar

does not have that person. This chapter shows that they do not need one to get most of the value. With one free catalog, a spreadsheet, and an hour a month, a small organization can know which of its systems are being attacked in the real world and fix those first.

What Threat Intelligence Is (and Is Not)

NIST describes cyber threat information as any information that helps an organization identify, assess, monitor, and respond to cyber threats, and it encourages organizations to use information shared by others even if they cannot produce their own (Johnson et al., 2016). In plain terms, threat intelligence answers one question: **what are attackers actually doing that could affect us?**

It is not a list of every possible weakness. A typical office computer has dozens of known vulnerabilities at any moment, and most of them are never used by attackers. Patching everything at once is impossible for a small team, so the real question is which few to patch first. That is where intelligence pays for itself.

The NIST Cybersecurity Framework 2.0 now makes this an expected practice. It asks organizations to receive cyber threat intelligence from information-sharing forums and sources (subcategory ID.RA-02) and to identify and record internal and external threats (ID.RA-03) (National Institute of Standards and Technology [NIST], 2024). Figure 4.1 shows where intelligence sits in a governance, risk, and compliance (GRC) program: it does not replace frameworks or deliverables; it keeps the risk scores between them current.

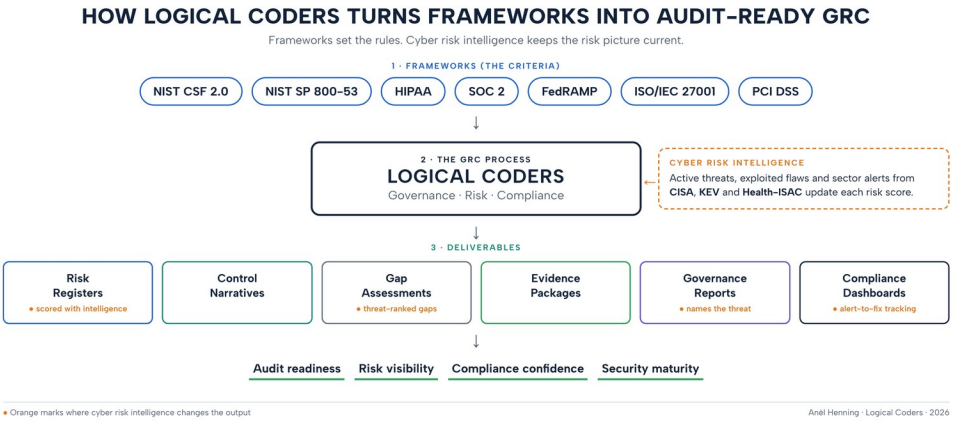


Figure 4.1 Frameworks set the rules; cyber risk intelligence keeps the risk picture current. Orange marks where intelligence changes the output, from scored risk registers to threat-ranked gap assessments.

One Free Catalog: Known Exploited Vulnerabilities

The Cybersecurity and Infrastructure Security Agency (CISA) publishes the **Known Exploited Vulnerabilities (KEV) catalog**, a public list of vulnerabilities for which CISA has reliable evidence of active exploitation. It began in November 2021 alongside a directive requiring federal agencies to fix listed vulnerabilities by set deadlines (Cybersecurity and Infrastructure Security Agency [CISA], 2021). Anyone can download it free as a spreadsheet or data file. On October 8, 2026, it held 1,739 entries (CISA, 2026).

For a small organization, the catalog has three big advantages. It is **short**, compared with the hundreds of thousands of vulnerabilities in public databases. It is **evidence-based**, because every entry is being used by attackers. And it is **practical**, because each entry names the vendor and product in ordinary terms, gives a recommended action, and says whether the vulnerability is known to be used in ransomware campaigns.

Table 4.1 What each KEV column tells you

Column	Example (CVE-2025-5777)	Why it matters to you
Vendor and product	Citrix · NetScaler ADC and Gateway	Match against your equipment list
Vulnerability name	Out-of-bounds read vulnerability	A plain description for your IT provider
Date added	July 10, 2025	When exploitation was

		confirmed: newer means more urgent
Known ransomware use	Known	The strongest signal that a small business is at risk
Required action	Apply vendor mitigations or stop using the product	What to ask your IT provider to do
Due date (federal)	July 11, 2025	How seriously CISA rates it; one day is an emergency

Look at that due date

CISA gave federal agencies **one day** to fix CVE-2025-5777 after adding it. Remote-access gateways like this one let attackers in from anywhere, and the remote desktop gateway in this chapter's worked example matches it. When the catalog moves that fast, a small office relying on a quarterly patch cycle is weeks or months behind the attackers.

The Five-Step Monthly Loop

Figure 4.2 shows the routine. Each step takes minutes once you have set it up, and each is mapped to the NIST CSF 2.0 categories an auditor would look for.

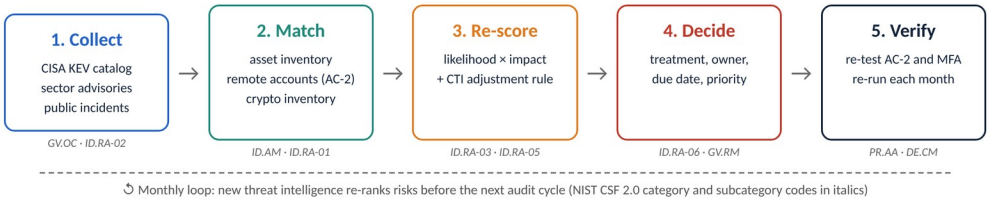


Figure 4.2 The five-step threat-intelligence loop. Repeat it every month, and whenever a major advisory for your sector is published.

Step 1. Collect

Download the current KEV catalog. Add one or two sources for your sector: CISA's #StopRansomware advisories, an information-sharing group such as Health-ISAC for healthcare, and the security advisories page of every vendor whose products you use. Write the date and catalog version at the top of your notes; your audit trail starts here.

Step 2. Match

Compare the catalog with your **asset inventory**: the list of every system, device, and software product you use. Most small

organizations do not have one, and building it is the most valuable hour in this chapter. For each item, record the vendor, the product, whether it can be reached from the internet, and who maintains it. Then, in a spreadsheet, count how many KEV entries name each vendor and product, how many were added in the last 24 months, and how many are linked to ransomware. Readers who code can use the free script in the companion repository, which does the same thing in seconds.

Use one simple rule to sort the results. An asset is a **priority** if it is internet-facing and has at least one recent entry linked to ransomware. It is on the **watch** list if it has any match. Everything else is **none for now**.

Step 3. Re-score

Your risk register scores each risk as likelihood times impact on a five-point scale (Joint Task Force Transformation Initiative, 2012). Intelligence changes the likelihood, not the impact. Use a rule simple enough that anyone can check it: add one point of likelihood if a linked asset is a priority asset, add one more if remote accounts lack MFA, and never go above five.

Step 4. Decide

Turn the new scores into three to five actions, each with an owner and a date. Use CISA's due dates as a guide to urgency. Then write a one-page summary the owner can understand in two minutes (see the box later in this chapter). If the decision-maker cannot read it, nothing will change.

Step 5. Verify

Next month, check that the actions happened. Re-test MFA coverage and account access (Chapter 6 gives a script). Confirm patched versions with your IT provider. Then start the loop again with the new catalog.

Build Your First Asset Inventory in an Afternoon

The loop is only as good as the list it matches against. You do not need special software to start; you need a spreadsheet and four questions, asked of the right people.

- **Ask the IT provider:** “What do we own that can be reached from the internet?” This usually means the firewall, any VPN or remote desktop service, the remote-support tool the provider uses to reach you, the website, and email. Write down the brand and product name of each.
- **Ask the office manager:** “Which online services do we log in to?” Practice-management, scheduling, payroll, banking, cloud storage, and the patient or customer portal. These are rented software; note who the vendor is and whether MFA is turned on.
- **Walk the office:** routers, Wi-Fi access points, printers, cameras, door systems, and anything with a network cable or a screen. Photograph the label; it has the model number.
- **Check the paperwork:** invoices and contracts list products and versions that nobody remembers buying.

Give each item an owner, the person who will be asked to act when it appears on the priority list. In a small organization, that may be the same IT provider for most items. That is fine; the point is that someone's name is next to every system. Then sort the list so that internet-facing items are at the top. Those are the ones the loop checks first, every month.

Design tip: make the inventory readable

Use one row per system, plain names first (“front-desk scheduling”) and product names second. Mark the internet-facing column with an outline, not a fill, so the sheet prints clearly in black and white. An inventory the office manager can read is an inventory that stays up to date.

Worked Example: Sunshine Dental Group

Sunshine Dental Group is a fictional 22-person practice with four offices in the Tampa area and about 9,800 patient records. It uses a practice-management system for electronic health records, lets staff work from home through a remote desktop gateway, and relies on a managed service provider (MSP) that connects through a remote-

support tool. Its baseline risk register, built before any threat intelligence, already rated ransomware and lost devices as Critical.

Match

Table 4.2 shows the results of matching Sunshine's five main systems against the catalog.

Table 4.2 Sunshine Dental Group: KEV matches by asset

Asset	Product searched	Internet-facing	All	Last 24 mo.	Ransomware (recent)	Flag
Remote desktop gateway	Citrix NetScaler	Yes	16	9	1	Priority
Perimeter firewall / VPN	Fortinet FortiOS	Yes	15	4	3	Priority
MSP remote support tool	ConnectWise ScreenConnect	Yes	4	3	1	Priority
Office workstations	Microsoft Windows	No	177	50	7	Watch
Practice-management / EHR app	Henry Schein Dentrix	No	0	0	0	None

Three systems are priorities, and all three are ways **into** the practice from the internet: the remote desktop gateway, the firewall's VPN, and the MSP's remote-support tool. That pattern repeats in almost every small organization: attackers prefer the front door. The office computers have many matches but sit behind the firewall, so they are on the watch list and handled by regular patching. The practice-management application has no matches at all, which leads to the first reading lesson below.

The account check found that **4 of 5 remote-access accounts lacked MFA**, including a shared front-desk login and the IT vendor's account: office.mgr, frontdesk, it.vendor, billing.

Re-score

Table 4.3 Sunshine Dental Group: risk scores before and after threat intelligence

ID	Risk	Before	After	Why
R-01	Ransomware on EHR via remote access	20 Critical	25 Critical	exposed asset has recent ransomware-linked KEV; remote accounts lack MFA
R-02	Unauthorized	20 Critical	25 Critical	remote accounts

	external access to patient portal			lack MFA
R-03	Lost or stolen mobile device with ePHI	20 Critical	20 Critical	no change
R-04	Phishing leads to email account takeover	15 Critical	15 Critical	exposed asset has recent ransomware-linked KEV; likelihood already at maximum
R-08	Insider misuse of remote access / VPN	12 High	20 Critical	exposed asset has recent ransomware-linked KEV; remote accounts lack MFA

Three risks rose. The most important change was insider misuse of remote access (R-08), which moved from High to Critical because its gateway is a priority asset and its accounts lack MFA. Two risks did not change, for instructive reasons. Lost or stolen devices (R-03) had no related intelligence; nothing in the catalog makes a phone more likely to be left in a taxi. Phishing (R-04) was linked to a priority asset, but its likelihood was already at the maximum, so the score could not rise.

Decide

One-page owner summary: Sunshine Dental Group, October 2026

What changed this month: attackers are actively using weaknesses in the same kind of remote-access products our offices use to let staff and our IT vendor connect from outside. Four of our five remote logins do not ask for a phone code.

Do this week: (1) Turn on phone-code login (MFA) for every remote account, including the IT vendor. Owner: IT vendor. Due: 7 days. (2) Ask the IT vendor to confirm in writing that the remote desktop gateway, firewall, and remote-support tool are patched. Owner: office manager. Due: 7 days.

Do this month: (3) Replace the shared front-desk login with individual logins. Owner: office manager. Due: 21 days.

Why it matters: this is the same weakness that started the 2024 Change Healthcare attack. A ransomware attack could stop scheduling and billing for weeks.

Cost: MFA is included in most of the systems we already pay for. Staff time: about 15 minutes per person.

Notice what the summary leaves out: CVE numbers, scores, and jargon. Those belong in the risk register and the auditor's file. The

owner needs to know what changed, what to do, who does it, by when, and why. This is human-centered design applied to a risk report, and it is the step that turns intelligence into action.

Verify

Next month, the office manager re-runs the account check. If MFA coverage is five of five and the vendor has confirmed the patches, the loop records the evidence and moves on. If not, the same three actions stay at the top of the list, and the owner sees that in the next summary.

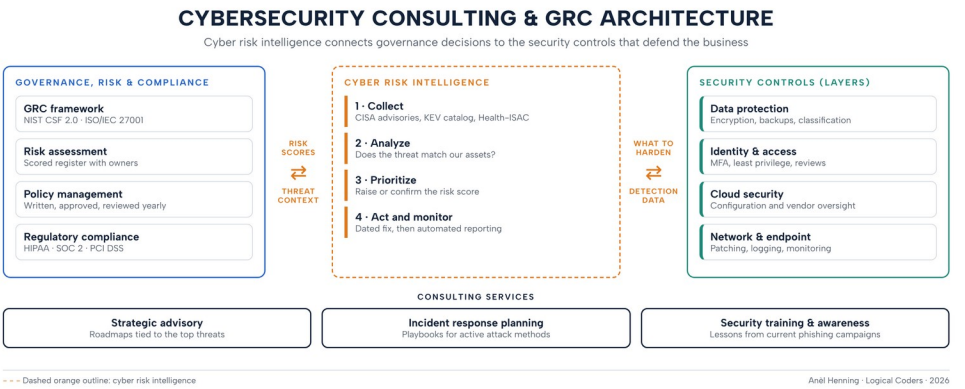


Figure 4.3 Cyber risk intelligence connects governance decisions to the security controls that defend the business: collect, analyze, prioritize, and act and monitor. The five-step loop is a small-organization version of this flow.

Reading the Results Without Fooling Yourself

A missing match is not proof of safety

Sunshine's practice-management system had no KEV entries. That does not mean it is safe; it means CISA has not confirmed exploitation of that product. The same was true of the student information system in this book's college case, yet a similar cloud platform, PowerSchool, was the route for a large theft of student records in December 2024 after an attacker used a compromised credential (PowerSchool, 2025). For software you rent rather than run, the catalog cannot see the risk. Check those vendors through contracts, their security pages, and the MFA settings on your own accounts with them.

The catalog sees what organizations use

When I searched the catalog for the device types used in this book's robotic grocery-cart concept, the results were uneven. Routers and wireless gateways had 26 entries added in the last 24 months, remote-access products had 21, and cameras and video recorders had 6. Smart-home and voice ecosystems had **none**. That does not mean doorbells and smart speakers are safe. Their best-known failures, such as the Ring and Alexa cases in Chapter 7, were about design and data handling, and they were documented by regulators rather than in a vulnerability catalog (Federal Trade Commission [FTC], 2023a, 2023b). Use more than one source.

Old CVEs can be new news

Some entries carry CVE numbers from years ago but were added to the catalog recently. The date added is what matters, because it marks when attackers were confirmed to be using the weakness. In this chapter's example, a 2019 firewall vulnerability was added in 2025 and linked to ransomware.

Check versions before you panic

Matching by vendor and product name can overstate the problem, because many entries apply only to certain versions. Treat a match as a question for your IT provider (*are we on an affected version?*), not as proof of compromise.

Watch for the ceiling

On a five-point scale, a risk already rated 5 for likelihood cannot rise. When many risks sit at the top, rank them within the band by the strength of the evidence: internet-facing with recent ransomware use first.

Beyond the Catalog: Other Free Sources

The KEV catalog is the backbone of the loop, but three other free sources fill its gaps.

Sector advisories. CISA's #StopRansomware advisories describe how specific groups break in, often naming the products and weaknesses they use. A December 2023 advisory, for example, warned that the

ALPHV/BlackCat group was targeting healthcare, two months before the Change Healthcare attack (Cybersecurity and Infrastructure Security Agency, Federal Bureau of Investigation, & U.S. Department of Health and Human Services, 2023). Industry sharing groups such as Health-ISAC offer similar alerts for members.

Vendor security pages. Every vendor in your inventory publishes advisories. Subscribe to the email alerts for your internet-facing products. When a vendor announces an urgent fix, you will often hear before the catalog is updated.

Regulatory and legal cases. For consumer devices, cloud services, and privacy, the most useful lessons often come from enforcement actions rather than vulnerability lists. The FTC's cases against Ring and Amazon are examples (FTC, 2023a, 2023b). They describe what went wrong in plain language and what the company had to change.

Pick one source of each kind and add them to Step 1. More sources are not always better; a short list that you actually read every month is worth more than a long list that you ignore.

What Three Small Organizations Revealed

The same loop was applied to three fictional organizations: Sunshine, a nine-store grocer piloting robotic carts, and a technical college. Across the three, 10 of 18 key systems were priority assets, 10 of 15 remote-access accounts lacked MFA, and threat intelligence raised 9 of 11 risks. Two patterns appeared everywhere. The most urgent systems were always the **edges**: VPNs, firewalls, remote-access gateways, and file-transfer servers. And missing MFA on remote and vendor accounts appeared in every case. Chapter 5 tells the grocer's and the college's stories in detail.

The grocer's case shows why intelligence about suppliers matters too. Its most urgent system was the server it uses to exchange orders with suppliers, which matched two catalog entries for a file-transfer product, both added in December 2024 and linked to ransomware. In 2024 and 2025, cyber incidents at a large grocery company and a major grocery distributor disrupted pharmacies, online orders, and deliveries (Ahold Delhaize USA, 2024; United Natural Foods, Inc.,

2025). A local store can do everything right inside its walls and still empty its shelves because a link in its supply chain was left open. The loop puts that link on the list.

If you do only two things

1. Make a list of everything that can be reached from the internet, and check it against the KEV catalog every month.
2. Require MFA on every remote and vendor account, with no exceptions for shared or “convenience” logins.

What It Costs and What It Saves

The catalog is free. The spreadsheet is free. Building the first asset inventory takes a few hours; after that, the monthly loop takes about an hour. The main saving is focus. Instead of trying to patch everything, a small team fixes the handful of systems attackers are using now, which also means fewer emergency weekends, less disruptive patching, and less wasted effort and energy on low-value work. The larger saving is the incident that does not happen: Chapter 1 showed that the average data breach cost USD 4.88 million in 2024 (IBM, 2024), a sum that would close most small practices.

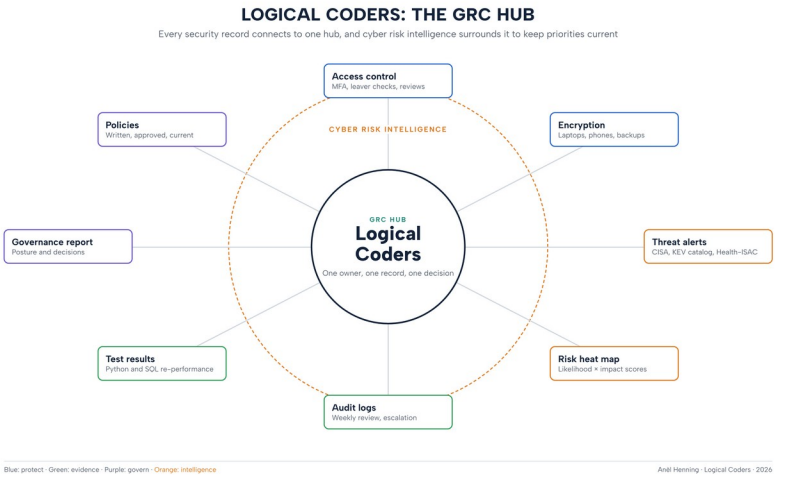


Figure 4.4 The GRC hub. Every security record connects to one place, and threat intelligence surrounds it to keep priorities current: one owner, one record, one decision.

Your Turn: Monthly Threat-Intelligence Log

Keep one row per asset per month. After three months, you will have the evidence trail an auditor or insurer expects.

Column	What to write
Month and catalog version	For example, October 2026 · KEV 2026.10.08
Asset	Name, vendor, product, version, owner
Internet-facing?	Yes or no
KEV matches	All · added in last 24 months · ransomware-linked
Flag	Priority · watch · none for now
Other sources checked	Sector advisory, vendor page, regulator case
Linked risks and new score	Risk ID, before → after, reason
Action, owner, due date	From the owner summary
Verified?	Date, evidence (screenshot, vendor letter, test result)

Chapter 4 Checklist

☐ I downloaded the current KEV catalog and recorded its version and date.

☐ I have an asset inventory with vendor, product, version, owner, and internet exposure.

☐ Each asset is flagged priority, watch, or none for now.

☐ I checked at least one source beyond the KEV catalog for my sector and for rented (cloud) software.

☐ Risk scores were updated with a written, repeatable rule.

☐ The owner received a one-page summary with actions, owners, and dates.

☐ Every remote and vendor account uses MFA, or has a dated plan to.

☐ Last month's actions were verified with evidence.

☐ The next monthly review is on the calendar.

Try It

Exercise 1 (20 minutes). Download the KEV catalog as a spreadsheet. Filter the vendor column for three brands your school, employer, or family uses (for example, your home router's maker). How many entries does each have? How many were added in the last 24 months? How many are linked to ransomware?

Exercise 2 (45 minutes). Write a five-line asset inventory for a small organization you know, run the companion script or a spreadsheet

match, and write a one-page owner summary using the example in this chapter. Ask someone without a technical background to read it. Could they act on it?

Questions for Discussion

- Why does the date an entry was added matter more than the year in its CVE number?
- Sunshine's practice-management system had no matches. What would you check instead?
- Should a risk score ever go down because of threat intelligence? Give an example.
- The owner summary leaves out CVE numbers. What is gained and what is lost?

References

Ahold Delhaize USA. (2024, November 11). *Ahold Delhaize USA statement on cybersecurity issue* [Press release].

Cybersecurity and Infrastructure Security Agency. (2021). *Binding Operational Directive 22-01: Reducing the significant risk of known exploited vulnerabilities*. https://www.cisa.gov/binding-operational-directive-22-01

Cybersecurity and Infrastructure Security Agency. (2026). *Known exploited vulnerabilities catalog* (Version 2026.10.08) [Data set]. https://www.cisa.gov/known-exploited-vulnerabilities-catalog

Cybersecurity and Infrastructure Security Agency, Federal Bureau of Investigation, & U.S. Department of Health and Human Services. (2023). *#StopRansomware: ALPHV Blackcat* (Advisory AA23-353A). https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-353a

Federal Trade Commission. (2023a, May 31). *FTC says Ring employees illegally surveilled customers, failed to stop hackers from taking control of users' cameras* [Press release].

Federal Trade Commission. (2023b, May 31). *FTC and DOJ charge Amazon with violating children's privacy law by keeping kids' Alexa voice recordings forever and undermining parents' deletion requests* [Press release].

IBM. (2024). *Cost of a data breach report 2024*. IBM Security.

Johnson, C., Badger, L., Waltermire, D., Snyder, J., & Skorupka, C. (2016). *Guide to cyber threat information sharing* (NIST Special Publication 800-150). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-150

Joint Task Force Transformation Initiative. (2012). *Guide for conducting risk assessments* (NIST Special Publication 800-30, Rev. 1). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-30r1

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST CSWP 29). https://doi.org/10.6028/NIST.CSWP.29

PowerSchool. (2025). *Cybersecurity incident* [Incident notice and FAQ]. https://www.powerschool.com/security/sis-incident/

United Natural Foods, Inc. (2025, June 9). *Form 8-K: Current report*. U.S. Securities and Exchange Commission.

Witty, A. (2024, May 1). *Testimony of Andrew Witty, Chief Executive Officer, UnitedHealth Group* [Testimony before the Subcommittee on Oversight and Investigations, Committee on Energy and Commerce, U.S. House of Representatives].

Note on the cases: Sunshine Dental Group and the other organizations in this chapter are fictional; their inventories and accounts are synthetic teaching data. KEV results are real matches against the public catalog, version 2026.10.08.